

Resumo Completo: "A Revised Framework of Information Security Principles"

Autores: André Teixeira e Filipe de Sá-Soares

Instituição: Centro ALGORITMI, Departamento de Sistemas de Informação, Universidade do Minho

Publicação: Proceedings of the European Information Security Multi-Conference EISMC 2013

Abstract

Este artigo revê e propõe um framework atualizado para os princípios da segurança da informação. Os princípios tradicionais de Confidencialidade, Integridade e Disponibilidade (modelo CIA) permanecem virtualmente inalterados ao longo do tempo, mas diversos autores argumentam que são claramente insuficientes para proteger a informação moderna^[2].

O objetivo deste trabalho é revisar o framework dos princípios de segurança da informação, tornando-o mais atual, completo e abrangente. Baseado numa revisão sistemática da literatura, um conjunto de princípios de segurança da informação é identificado, definido e caracterizado, levando subsequentemente a uma proposta de Framework Revisado de Princípios de Segurança da Informação^[2].

O framework foi avaliado em termos de completude através do cruzamento com um catálogo de ameaças resultante da fusão de quatro catálogos existentes. Um conjunto inicial de métricas de segurança, aplicadas diretamente aos princípios que constituem o framework, é também sugerido, permitindo, em caso de eventos adversos, avaliar a extensão em que cada princípio foi comprometido^[2].

1. Introdução

1.1 Contexto e Motivação

A generalização dos Sistemas de Informação (SI) para todas as áreas da sociedade, aliada à constante evolução da Tecnologia da Informação (TI), configura um ecossistema onde é relativamente barato e fácil armazenar, processar e partilhar informação^[2]. Este ecossistema apresenta várias oportunidades para organizações e indivíduos, alterando profundamente a forma como comunicam, organizam e interagem, mas também levanta uma série de riscos às atividades de manipulação da informação^[2].

Tradicionalmente, a proteção da informação e SI tem sido orientada por três princípios básicos: Confidencialidade, Integridade e Disponibilidade, frequentemente referidos como o modelo CIA^[2]. Contudo, alguns autores argumentam que estes princípios, embora basilares e importantes, podem não ser suficientes pois não abordam todas as ameaças de Segurança da Informação (InfoSec) e não evoluíram ao mesmo ritmo das ameaças^[2].

1.2 Críticas ao Modelo CIA

Parker (1998) observou: "Necessitamos de um novo modelo para substituir as atuais descrições inarticuladas, incompletas e incorretas da segurança da informação. Os modelos atuais limitam o âmbito da segurança da informação principalmente à tecnologia informática e ignoram as fontes dos problemas que a segurança da informação aborda. Também empregam significados incorretos para as palavras que usam e não incluem alguns dos tipos importantes de perdas como roubo de cópias de informação e representação de informação"[^2].

Ao longo dos anos, a insatisfação com o modelo CIA levou diversos autores a redefinir princípios existentes ou a propor novos princípios que complementam e atualizam os tradicionais, incluindo Parker (1998), Dhillon e Backhouse (2000), Stamp (2006), e Whitman e Mattord (2011)[^2].

1.3 Definição de Princípios de Segurança da Informação

Os autores usam a expressão "princípios de segurança da informação" para significar aqueles atributos da informação e outros recursos de SI que podem funcionar como diretrizes, objetivos ou pontos focais para os esforços de proteção da informação[^2]. A importância dos princípios é que ao identificá-los estamos realmente definindo segurança da informação, deduzindo deles objetivos, preocupações e âmbito da InfoSec[^2].

2. Análise da Literatura sobre Princípios de Segurança da Informação

2.1 Metodologia de Revisão

O primeiro passo foi a identificação e caracterização dos atributos que a literatura indica explícita ou implicitamente como princípios de segurança da informação[^2]. Foram usadas três fontes principais de definições:

1. **Dicionários:** Dicionário da língua portuguesa da Academia das Ciências de Lisboa e dicionário Merriam-Webster[^2]
2. **Publicações de organizações internacionais:** Standards da ISO, NIST, bem como referências historicamente relevantes como ITSEC, GAISP e COBIT[^2]
3. **Documentos de autores individuais:** Onde autores delinearam seu entendimento dos princípios InfoSec[^2]

Destas fontes, foram identificados um total de dezassete atributos de segurança[^2]. Para comparar as definições, estabeleceram um esquema composto por quatro parâmetros: âmbito, natureza, objeto e propósito[^2].

2.2 A Tríade Tradicional

2.2.1 Confidencialidade

A confidencialidade é um dos três princípios básicos e tradicionais da InfoSec, provavelmente o mais facilmente e frequentemente associado com segurança^[2]. Historicamente, tem raízes militares e foi o primeiro princípio formalizado num documento seminal InfoSec – o TCSEC (Trusted Computer System Evaluation Criteria), baseado no modelo Bell-LaPadula^[2].

Este é o princípio que lida com o sigilo, cobrindo informação no armazenamento, durante processamento e enquanto em trânsito^[2]. O propósito da confidencialidade é, segundo a maioria dos autores, não divulgar, não tornar disponível e não permitir acesso à informação por entidades não autorizadas^[2].

Autores como Parker (1998) e Pfleeger e Pfleeger (2003) chamaram atenção para o facto de a confidencialidade não dever ter como única preocupação a divulgação de informação secreta, mas também observação voluntária ou involuntária, impressão ou simplesmente saber que um ativo particular de informação existe^[2].

2.2.2 Integridade

O princípio da integridade é também parte do modelo tradicional de InfoSec. Seguiu a confidencialidade em termos de formalização, transmitida no modelo Biba^[2]. Subjacente ao conceito de integridade está a noção de mudança, com a maioria das definições abordando o acesso aos recursos de informação e o processo de autorização associado^[2].

Considerando o propósito da integridade, há duas grandes correntes distintas:

1. A integridade garante que a informação seja completa, precisa e correta
2. A integridade refere-se à prevenção de manipulação, modificação e destruição não autorizadas^[2]

Uma questão relevante associada com integridade é a sua dimensão contextual e comportamental^[2]. A definição do ITGI (2007) salienta que a precisão, completude e validade da informação devem ser julgadas de acordo com os valores e expectativas do negócio^[2].

2.2.3 Disponibilidade

A disponibilidade é o terceiro componente do modelo tradicional para InfoSec. Provavelmente, é o princípio cujo comprometimento é mais imediatamente evidente para os utilizadores^[2].

Uma questão importante relaciona-se com o acesso e possibilidade de usar informação e sistemas de forma oportuna^[2]. Em contraste com os dois princípios anteriores, a preocupação com acesso não é unicamente colocada na sua restrição, mas a principal preocupação é ser capaz de conceder acesso àqueles com direito a ele^[2].

Embora o acesso à informação seja importante, a definição avançada pelas normas ISO sugere que ser capaz de aceder à informação não implica que a informação seja utilizável^[2]. A usabilidade da informação já tinha sido notada por Parker (1998) e elaborada por Whitman e Mattord, que qualificam acesso em termos de autorização, formato e obstrução^[2].

2.3 Extensões da Tríade

Após revisar o modelo CIA, o artigo apresenta definições para um conjunto de dez atributos que não fazem parte do framework tradicional InfoSec, mas podem funcionar como extensões da tríade CIA^[2]:

2.3.1 Privacidade

A privacidade é um dos tópicos mais discutidos no campo da InfoSec e provavelmente um dos mais facilmente entendidos pela sociedade em geral^[2]. Este é um conceito intimamente relacionado com o conceito de confidencialidade^[2].

Relativamente ao propósito, há dois sentidos distintos:

1. Controlo da informação pessoal detida por terceiros, incluindo controlo sobre a divulgação dessa informação
2. Não intrusão, anonimato, não ligação, não detetabilidade e não observabilidade^[2]

2.3.2 Fiabilidade

O princípio da fiabilidade, ao contrário dos princípios anteriormente revistos, é principalmente proposto no domínio dos sistemas em vez da informação^[2]. O objeto que é principalmente visado pelas definições é o sistema, com o propósito do princípio sendo a continuidade da entrega de serviços ou o funcionamento sem falhas de um sistema^[2].

2.3.3 Autenticidade

Em contraste com a fiabilidade, o princípio da autenticidade é aplicável à própria informação^[2]. É também frequentemente aplicado a processos e pessoas^[2].

À primeira vista, há um certo grau de sobreposição entre autenticidade e integridade. Provavelmente, um dos principais apoiadores da distinção entre os dois princípios é Parker (1998)^[2]. Este autor propôs um par de princípios formado por integridade e autenticidade, no qual o primeiro se relaciona com completude, e o segundo com validade^[2]. Segundo a sua perspetiva, uma entidade é autêntica se representa os factos desejados e a realidade^[2].

2.3.4 Não-Repúdio

O não-repúdio partilha algumas das características da autenticidade^[2]. Este princípio desempenha um papel central na segurança das comunicações, onde é importante provar que uma mensagem originou de um remetente específico (não-repúdio de origem) e que uma mensagem foi aceite por um recetor específico (não-repúdio de receção)^[2].

O ponto essencial deste conceito repousa na capacidade de garantir que um certo evento ocorreu ou não ocorreu e, no primeiro caso, ser capaz de identificar as entidades envolvidas^[2].

2.3.5 Accountability (Responsabilização)

A accountability é apresentada por diversos autores como um princípio InfoSec, apesar de não se aplicar diretamente à informação em si, mas às pessoas que manipulam informação^[2].

O propósito da accountability partilha semelhanças com o propósito do não-repúdio, em que ambos procuram atribuir responsabilidade por eventos ou ações a uma dada entidade^[2]. A principal preocupação é ser capaz de atribuir e imputar a uma entidade específica as consequências de uma certa ação ou decisão que foi prejudicial à segurança dos SI^[2].

2.3.6 Segurança (Safety)

Nas definições analisadas, safety é usado no domínio dos sistemas, e há consenso significativo relativamente ao propósito deste princípio, nomeadamente a ausência de consequências catastróficas no ambiente e pessoas^[2]. Ao centrar o conceito nos efeitos do mau comportamento dos sistemas, os proponentes classificam consequências como catastróficas, circunscrevendo o conceito às situações onde os resultados excedem um certo limiar^[2].

2.3.7 Sobrevivabilidade

Como no caso de outros conceitos já revistos, a sobrevivabilidade é apresentada não como um princípio aplicado diretamente à informação, mas aplicado a sistemas em geral^[2]. Relativamente à natureza, a sobrevivabilidade é geralmente apresentada como uma capacidade do sistema, cujo propósito é manter operação mesmo na presença de falhas ou ataques^[2].

Este princípio está inter-relacionado com o traço de resiliência dos sistemas, entendido como a capacidade de responder e recuperar rapidamente de situações de crise^[2].

2.3.8 Utilidade

No campo da InfoSec, o princípio da utilidade aparece no framework proposto por Parker (1998)^[2]. Parker articula o princípio da utilidade com o princípio da disponibilidade, relacionando o primeiro com a utilidade da informação e o segundo com a usabilidade da informação^[2].

Para ilustrar a diferença entre esses princípios, Parker delineia um cenário onde um empregado que rotineiramente encripta a única cópia de informação valiosa armazenada no seu computador, acidentalmente apaga a chave de encriptação do ficheiro^[2]. Neste caso, a disponibilidade da informação é mantida, mas a sua utilidade é perdida^[2].

2.3.9 Precisão

O conceito de precisão é usado em muitos contextos variados. No campo da InfoSec foi introduzido por Whitman e Mattord (2011) no seu modelo expandido de características críticas da informação^[2].

Whitman e Mattord (2011) combinam no princípio da precisão da informação a liberdade de erros e falhas e a existência do valor que o utilizador final espera^[2]. Em contraste com as definições de integridade, situações descritas diferem do facto de os agentes estarem autorizados a alterar a informação, contudo, modificam-na para um valor incorreto^[2].

2.3.10 Posse

O princípio da posse da informação é parte do modelo InfoSec expandido proposto por Parker (1998) [^2]. A partir destas definições, é salientado o aspeto do controlo da informação[^2]. Hoje em dia, parece consensualmente aceite que propriedade e controlo da informação são talvez as fontes mais importantes de poder nas organizações[^2].

Parker (1998) justifica a adição deste princípio ao modelo tradicional para que os esforços InfoSec possam prevenir certos tipos de perdas, como roubo de informação[^2]. Por definição, o princípio da posse lida apenas com o que as pessoas possuem e sabem, não com o que possuem sem saber[^2].

2.4 Complementos à Tríade - Modelo RITE

Nesta secção revisam-se quatro princípios propostos por Dhillon e Backhouse (2000) que constituem uma clara partida da tríade CIA[^2]. Em vez de restringir a sua atenção à informação armazenada ou em trânsito em processadores de silício (computadores e redes), esses autores focaram os desafios de segurança colocados e enfrentados por processadores biológicos de informação (pessoas)[^2].

Os Quatro Princípios RITE:

Responsabilidade: Contrastando com accountability, este princípio refere-se à responsabilidade que cada membro de uma organização deve observar ao desempenhar a sua função[^2]. A relevância da responsabilidade é mais aguda quando surgem novas circunstâncias na organização e torna-se necessário alguém assumir voluntariamente a responsabilidade para lidar com essas mesmas circunstâncias[^2].

Integridade (pessoal): Nas organizações de hoje a informação é um dos ativos mais valiosos, contudo, é um ativo que por sua natureza pode ser facilmente divulgado a partes não autorizadas[^2]. Embora a designação deste princípio seja a mesma que compõe a tríade CIA, neste contexto a integridade está ligada à lealdade dos membros da organização[^2].

Confiança: A confiança, em oposição ao controlo externo, é de particular importância em organizações geograficamente difusas onde os membros não podem controlar uns aos outros e "supervisão física" não é uma opção[^2]. Espera-se que cada membro atue de acordo com as normas e padrões de comportamento aceites e implementados pela organização[^2].

Eticidade: Este princípio advoga que os membros de uma organização devem adotar comportamentos éticos mesmo se estes não estão formalmente definidos e implementados[^2]. Lida essencialmente com as relações informais que se estabelecem dentro da organização e com comportamento em situações novas sem regras pré-definidas[^2].

3. Relacionando Ameaças InfoSec com Princípios InfoSec

No campo da InfoSec as ameaças são um conceito fundamental[^2]. Uma maneira de conectar ameaças e seus impactos potenciais nos ativos dos sistemas de informação é considerando que princípios InfoSec podem estar em perigo se as ameaças se materializam[^2].

Para obter uma melhor compreensão dos princípios InfoSec revistos, os autores cruzaram os princípios com uma bateria de ameaças InfoSec^[2]. Este exercício serviu como teste no âmbito e completude da lista de princípios^[2].

3.1 Catálogo Unificado de Ameaças (UTC)

Para operacionalizar este teste condensaram um Catálogo Unificado de Ameaças (UTC) que resultou da fusão de quatro catálogos distintos de ameaças e ataques:

1. **Federal Office for Information Security (BSI 2005)**: 370 ameaças detalhadas organizadas em cinco capítulos
2. **Financial Services Roundtable's Technology Task Force (BITS 2004)**: 622 riscos genéricos em 70 categorias de ameaças
3. **Microsoft (Microsoft 2007)**: 36 ataques detalhados organizados em 19 ataques de alto nível
4. **Fred Cohen – Sandia National Laboratories (Cohen 1997)**: 94 métodos de ataque^[2]

O UTC final foi composto por 422 ameaças organizadas em cinco categorias e 32 subcategorias^[2]:

- **Force Majeur** (13 ameaças)
- **Organizational Shortcomings** (104 ameaças)
- **Human Failure** (82 ameaças)
- **Technical Failure** (55 ameaças)
- **Deliberate Acts** (169 ameaças)^[2]

3.2 Resultados do Cruzamento

O processo de relacionar ameaças com princípios resultou em quatro proposições importantes:

3.2.1 Reinterpretação do Princípio de Sobrevivabilidade

Considerando que nenhuma das ameaças do UTC correspondia a este princípio, foi reinterpretado como contribuidor para a disponibilidade^[2]. A sobrevivabilidade é percebida como uma habilidade de um sistema para suportar situações severas^[2].

3.2.2 Descarte do Princípio de Segurança (Safety)

Como definido por vários autores, safety significa a ausência de consequências catastróficas no ambiente causadas por um dado sistema^[2]. Não foi possível atribuir qualquer das ameaças do UTC à segurança^[2].

3.2.3 Proposta do Princípio de Legalidade

Durante o processo de cruzamento, foi descoberto que algumas ameaças relacionadas com consequências legais para a organização, e que poderiam comprometer a InfoSec, não podiam ser correspondidas a nenhum dos princípios identificados^[2]. Assim, propõem a inclusão de um novo princípio, chamado legalidade, para abordar essas ameaças particulares^[2].

3.2.4 Manutenção dos Princípios RITE

Analisando os resultados do processo de cruzamento, nota-se que os princípios RITE têm uma expressão reduzida em termos do número de ameaças que podem impactar esses princípios^[2]. Contudo, argumentam que uma das deficiências do UTC é sua aderência aos princípios tradicionais InfoSec, deixando de fora outros princípios potenciais, especialmente aqueles que complementam confidencialidade, integridade e disponibilidade^[2].

4. Proposta de um Framework Revisado de Princípios de Segurança da Informação

4.1 O Framework Revisado

O framework proposto consiste em treze princípios e cinco sub-princípios, organizados em cinco dimensões distintas^[2]:

Dimensão "To Know" (Saber)

- **Confidencialidade:** Informação é apenas divulgada ou observada por indivíduos, entidades e processos autorizados pelo seu proprietário^[2]
- **Privacidade** (sub-princípio): Informação para identificar, detetar, associar ou rastrear um indivíduo é apenas divulgada ou observada por indivíduos, entidades e processos autorizados por esse indivíduo ou designados por lei^[2]
- **Posse:** Informação é detida e controlada pelo seu proprietário ou por indivíduos, entidades e processos autorizados por ele^[2]

Dimensão "To Change" (Mudar)

- **Integridade:** Informação e sistemas são modificados de forma autorizada apenas por indivíduos, entidades e processos autorizados pelo proprietário desses ativos^[2]
- **Autenticidade:** Informação está de acordo com uma realidade particular, e sua genuinidade e validade são verificáveis, ou um indivíduo, entidade ou processo é quem afirma ser^[2]
- **Precisão:** Informação está livre de erros, falhas e omissões^[2]

Dimensão "To Use" (Utilizar)

- **Disponibilidade:** Informação e os sistemas que a suportam são utilizáveis sempre que requerido por indivíduos, entidades ou processos autorizados pelos seus proprietários^[2]
- **Fiabilidade** (sub-princípio): Sistema desempenha sua função sem falha durante um período determinado de tempo^[2]
- **Sobrevivabilidade** (sub-princípio): Sistema entrega serviços essenciais na presença de ataques, falhas ou acidentes^[2]
- **Utilidade:** Informação ou sistemas podem ser usados para servir um propósito dado definido pelos seus proprietários^[2]

Dimensão "To Comply" (Cumprir)

- **Rastreabilidade:** Ações relevantes para InfoSec são demonstráveis e imputáveis aos seus autores^[2]
- **Não-Repúdio** (sub-princípio): Ações relevantes para InfoSec são conhecidas e não podem ser negadas ou escondidas pelos seus autores, ou injustificadamente alegadas como executadas por algum agente^[2]
- **Accountability** (sub-princípio): Ações relevantes para InfoSec são atribuíveis aos indivíduos responsáveis por essas ações^[2]
- **Legalidade:** Procedimentos relacionados com InfoSec cumprem leis aplicáveis, estatutos, regulamentos e obrigações contratuais, salvaguardando a responsabilidade da organização numa base civil e criminal^[2]

Dimensão "To Be" (Ser)

- **Responsabilidade:** Cada membro de uma organização tem uma compreensão clara dos seus papéis e responsabilidades, assumindo responsabilidades ad hoc quando novos desenvolvimentos o requerem^[2]
- **Integridade** (pessoal): Cada membro de uma organização é leal à organização e permanece assim^[2]
- **Confiança:** Cada membro de uma organização comporta-se de acordo com as normas e padrões de comportamento aceites e acordados pela organização^[2]
- **Eticidade:** Cada membro de uma organização adota um comportamento ético mesmo que as práticas éticas não sejam formalizadas ou declaradas^[2]

4.2 Relações entre Princípios do Framework

O artigo apresenta relações entre alguns princípios na forma de proposições de implicação lógica^[2]:

1. **¬Confidencialidade ⇒ ¬Posse:** A violação da confidencialidade implica violação da posse^[2]
2. **¬Privacidade ⇒ ¬Confidencialidade ⇒ ¬Posse:** A violação da privacidade implica violação da confidencialidade e posse^[2]
3. **¬Disponibilidade ⇒ ¬Utilidade:** A violação da disponibilidade implica violação da utilidade^[2]
4. **¬Autenticidade ⇒ ¬Rastreabilidade:** A violação da autenticidade implica violação da rastreabilidade^[2]

4.3 Revisitando a Relação entre Ameaças InfoSec e Princípios InfoSec

O framework proposto combina definições para os princípios constituintes com uma estruturação dos princípios^[2]. A análise das relações fornece uma visão holística e quantitativa das relações entre ameaças InfoSec e os princípios InfoSec conforme propostos no framework^[2].

Os resultados refletem as relações de implicação descritas, com os princípios de Posse, Disponibilidade, Utilidade, Confidencialidade e Integridade sendo os mais afetados^[2]. Os catálogos

de ameaças que levaram ao UTC geralmente seguem o modelo CIA tradicional, o que ajuda a explicar a prevalência de ameaças nos princípios InfoSec tradicionais^[2].

5. Métricas para os Princípios de Segurança da Informação

Após apresentar o framework revisado de princípios InfoSec, os autores abordam a questão da medição^[2]. Sugerem para cada princípio métricas que podem assistir, em caso de ataque ou falha, a avaliar a extensão em que esse princípio foi comprometido^[2].

5.1 Estado da Arte em Métricas InfoSec

A investigação em métricas InfoSec é relativamente recente e não há referências consolidadas amplamente aceites pela comunidade científica, profissionais InfoSec e gestores para avaliar o nível de InfoSec de uma organização^[2]. A inexistência de referências de medição deriva de vários fatores, incluindo:

- Dificuldade de medir InfoSec
- Dependência de inputs subjetivos, humanos e qualitativos
- Meios ilusórios para obter medições
- Falta de compreensão dos mecanismos de segurança da informação
- Imaturidade dos esforços de investigação
- Fragmentação das áreas de conhecimento^[2]

5.2 Características das Métricas Propostas

As métricas sugeridas são puramente conceituais resultando diretamente das definições adotadas para cada um dos princípios InfoSec e carecem de testes em ambientes reais^[2]. Duas das principais características do conjunto de métricas propostas são sua simplicidade e natureza *ex post*^[2]:

- **Simplicidade:** São simples de entender e quantificar, embora algumas requeiram coleta de dados base e estabelecimento de estruturas correspondentes de coleta de dados^[2]
- **Natureza *ex post*:** São medidas a posteriori, focando em eventos após o facto, fornecendo indicações sobre comprometimento de princípios InfoSec^[2]

5.3 Exemplos de Métricas por Dimensão

Dimensão "To Know":

- % de informação confidencial/privada observada ou divulgada a entidades não autorizadas
- Número de entidades não autorizadas que acederam informação
- % de informação que já não é exclusivamente detida e controlada^[2]

Dimensão "To Change":

- % de informação/sistemas modificados ou manipulados por entidades não autorizadas
- % de informação não genuína e inválida face à realidade
- Número de erros, omissões e falhas detetadas na informação^[2]

Dimensão "To Use":

- % de informação/sistemas disponíveis
- Tempo de inatividade
- Frequência de falhas
- Tempo médio entre falhas^[2]

Dimensão "To Comply":

- % de ações relevantes para InfoSec cujos autores são desconhecidos
- Número de processos legais resultantes de procedimentos ilegais relacionados com InfoSec^[2]

Dimensão "To Be":

- Número de incidentes InfoSec que resultaram da falta de compreensão clara dos papéis de um membro organizacional
- % de membros que se envolveram com partes externas em ações prejudiciais ao nível InfoSec da organização^[2]

6. Conclusão

A crescente dependência das organizações na informação e TI justifica a existência de referências atualizadas que assistam organizações a proteger seus ativos informacionais^[2]. Ao longo do tempo, vários autores argumentaram por uma atualização do grupo de princípios que pode orientar os esforços de segurança da informação das organizações^[2].

6.1 Contribuições do Trabalho

Em vista desta necessidade contínua de reconsiderar os fundamentos que definem segurança da informação, os autores propuseram um framework revisado de princípios de segurança da informação estruturado em cinco dimensões contendo treze princípios e cinco sub-princípios^[2]. Cada componente do framework foi definido e complementado com um conjunto básico e inicial de métricas^[2].

6.2 Aplicações e Benefícios

Os autores esperam que estas contribuições possam provar-se úteis para a gestão da segurança da informação em organizações, assistindo seus stakeholders a envolver-se num diálogo sobre os objetivos da proteção da informação e os meios que melhor realizam a obtenção de um nível apropriado de segurança da informação^[2].

6.3 Direções Futuras

O framework proposto de princípios de segurança da informação não é final e deve estar aberto a debate e revisão^[2]. É expectativa dos autores que possa promover:

- Desenvolvimento de um catálogo atualizado de ameaças de segurança da informação intimamente relacionado ou enraizado nestes princípios
- Surgimento de novas insights sobre métricas de eficácia InfoSec mais maduras e sofisticadas^[2]

6.4 Limitações Reconhecidas

- Métricas puramente conceituais sem testes em ambientes reais
- Catálogos de ameaças podem ainda estar enviesados para o modelo CIA tradicional
- Framework deve permanecer aberto a debate e revisão^[2]

Uma importante linha futura de investigação seria definir um conjunto alternativo de métricas, diretamente conectadas aos princípios InfoSec, que em vez de avaliar a extensão em que cada princípio foi comprometido, indica quão bem um controlo de segurança particular contribui para a preservação desses princípios^[2].

Bibliografia Principal

- Parker, D. B. (1998). Fighting Computer Crime: A New Framework for Protecting Information
- Dhillon, G., & Backhouse, J. (2000). Information system security management in the new millennium
- Whitman, M. E., & Mattord, H. J. (2011). Principles of Information Security
- ISO/IEC 27000 series standards
- NIST Special Publications on Information Security

Este resumo apresenta de forma completa e estruturada todos os conceitos, metodologias, resultados e conclusões do artigo original de Teixeira e Sá-Soares (2013), fornecendo uma base sólida para compreensão abrangente do framework proposto para princípios de segurança da informação.

[1]

*
*

